STUDY NOTES

AWS CloudTrail & Config

Comprehensive notes on cloud governance, audit logging, compliance monitoring, and automated resource tracking in AWS.

DATE	TOPIC	SERVICES
3 April 2026	**Cloud Governance**	**CloudTrail · Config · CloudWatch**

TABLE OF CONTENTS

01 Introduction

02 CloudTrail Architecture & Core Concepts

03 Event Structure & Key Fields

04 Trail Configuration

05 Event Types Deep Dive

06 Multi-Account Strategies

07 Cost Management & Optimization

08 Best Practices

09 Pitfalls & Remedies

10 Summary & Key Takeaways

11 Hands-On Lab Exercise

SECTION 01

Introduction

Every AWS API call — whether launching an EC2 instance, deleting an S3 bucket, modifying a security group, or accessing Secrets Manager — represents a potential security event, compliance requirement, or operational change requiring audit trails.

Traditional IT audit approaches — manual log reviews, periodic compliance checks, reactive incident investigation — cannot keep pace with cloud environments where infrastructure changes occur thousands of times daily. **AWS CloudTrail** and **AWS Config** solve these challenges through comprehensive API logging, continuous compliance monitoring, and automated resource tracking.

> **THE COST OF INADEQUATE LOGGING**
>
> Average data breach investigations require **280 days** without proper audit trails. Regulatory penalties reach millions for HIPAA and PCI DSS violations. Security incidents become impossible to investigate when API call history is missing.

Service	Primary Role	Answers the Question
CloudTrail	Records every API action taken in your AWS account (who, what, when, from where)	"Who did what and when?"
AWS Config	Continuously records resource configurations, evaluates compliance, tracks changes	"What resources exist and are they compliant?"

SECTION 02

CloudTrail Architecture & Core Concepts

Purpose

- Audit log of **all API calls** in an AWS account
- Foundation for security analysis, troubleshooting, and compliance reporting

Event Types at a Glance

MANAGEMENT

Management Events

Control plane operations — creating, modifying, and deleting resources.

Examples: RunInstances, CreateBucket, PutBucketPolicy

Logged by default · First copy free

DATA

Data Events

Data plane / object-level operations (high volume). Must be explicitly enabled.

Examples: GetObject (S3), PutObject, Invoke (Lambda)

Additional charges apply

INSIGHTS

Insights Events

Unusual API activity detected via machine learning. Early warning of security issues.

Examples: Spike in IAM actions, unusual API error rates

Additional charges apply

Log Delivery Flow

API Call → **CloudTrail Service** → **S3 Bucket** (within 15 min) →
CloudWatch Logs (near real-time) → **SNS Notification** (optional)

S3 Bucket Structure

```
s3://my-cloudtrail-bucket/ └── AWSLogs/ └── 123456789012/ (Account ID) └── CloudTrail/
└── us-east-1/ └── 2025/01/15/ ├── 123456789012_CloudTrail_us-east-
1_20250115T1030Z_abc.json.gz └── 123456789012_CloudTrail_us-east-
1_20250115T1045Z_def.json.gz
```

Log files are **gzip-compressed JSON**, delivered in approximately 5-minute batches.

Log File Validation (Digest Files)

WHY THIS MATTERS

Digest files contain **SHA-256 hashes** of each log file, providing cryptographic proof that logs have not been tampered with — essential for compliance and forensic investigations.

SECTION 03

Event Structure & Key Fields

Every CloudTrail event is a JSON record capturing the full context of an API call. The example below shows a `TerminateInstances` event:

```
{
  "eventVersion": "1.08",
  "userIdentity": {
    "type": "IAMUser",
    "principalId": "AIDACKCEVSQ6C2EXAMPLE",
    "arn": "arn:aws:iam::123456789012:user/Alice",
    "accountId": "123456789012",
    "userName": "Alice"
  },
  "eventTime": "2025-01-15T10:30:00Z",
  "eventSource": "ec2.amazonaws.com",
  "eventName": "TerminateInstances",
  "awsRegion": "us-east-1",
  "sourceIPAddress": "203.0.113.1",
  "userAgent": "aws-cli/2.0.0",
  "requestParameters": {
    "instancesSet": { "items": [{"instanceId": "i-1234567890abcdef0"}] }
  },
  "responseElements": {
    "instancesSet": {
      "items": [{
        "instanceId": "i-1234567890abcdef0",
        "currentState":  {"code": 32, "name": "shutting-down"},
        "previousState": {"code": 16, "name": "running"}
      }]
    }
  },
  "eventType": "AWSApiCall",
  "managementEvent": true,
  "readOnly": false
}
```

Key Field Reference

`userIdentity`	**Who** made the call — IAM user, role, service, or root user; includes the access key ID used.

`eventName`	**What** action was performed (e.g., `TerminateInstances`, `DeleteBucket`).
`eventTime`	**When** — UTC timestamp of the API call.
`sourceIPAddress`	**From where** — client IP address, or AWS service IP for service-to-service calls.
`requestParameters`	**What was requested** — full API call parameters and resource identifiers.
`responseElements`	API response including created resource IDs.
`errorCode`	Present when the call failed (e.g., `AccessDenied`, `InvalidParameter`).

SECTION 04

Trail Configuration

Trail Components

- **Name** — unique identifier for the trail
- **S3 bucket** — destination for log files
- **Log file validation** — integrity checking via SHA-256 digest files
- **CloudWatch Logs** — optional near real-time delivery
- **SNS topic** — optional event notifications
- **Tags** — resource organization

Trail Scope Options

Trail Type	Scope	Recommendation
Single-Region	Logs events in one AWS region only	Use only for region-specific compliance requirements

Multi-Region	All regions (IAM, Route 53 always in us-east-1)	Recommended for most use cases
Organization	All accounts in an AWS Organization; master account pays	Best practice for enterprises — centralized audit logging

CloudWatch Logs Integration

Integrating CloudTrail with CloudWatch Logs provides near real-time availability (vs. the 15-minute S3 delay), enabling metric filters, alarms, and Logs Insights queries.

```
cloudtrail.update_trail(
    Name='my-trail',
    CloudWatchLogsLogGroupArn='arn:aws:logs:region:account:log-group:cloudtrail',
    CloudWatchLogsRoleArn='arn:aws:iam::account:role/CloudTrailCloudWatchLogsRole'
)
```

CLOUDWATCH LOGS COSTS

- S3 storage: **$0.023 / GB-month**
- CloudWatch Logs ingestion: **$0.50 / GB**
- CloudWatch Logs storage: **$0.03 / GB-month**
- Typical volume: 0.5 – 5 GB per million API calls

SECTION 05

Event Types Deep Dive

Management Events (Control Plane)

Category	Example API Calls
IAM & Security	`CreateUser`, `DeleteUser`, `AttachRolePolicy`, `CreateAccessKey`, `PutUserPolicy`

Resource Creation	`RunInstances`, `CreateBucket`, `CreateFunction`, `CreateDBInstance`
Configuration Changes	`ModifyInstanceAttribute`, `PutBucketPolicy`, `UpdateFunctionConfiguration`
Resource Deletion	`TerminateInstances`, `DeleteBucket`, `DeleteFunction`, `DeleteDBInstance`
Network Changes	`CreateSecurityGroup`, `AuthorizeSecurityGroupIngress`, `CreateVpc`, `CreateSubnet`

Pricing: First copy free. Additional copies: **$2.00 per 100,000 events**.

Data Events (Data Plane)

High-volume, object-level operations that must be explicitly enabled:

- **S3 Object-Level:** `GetObject`, `PutObject`, `DeleteObject`, `GetObjectAcl`
- **Lambda Invocations:** `Invoke` (function execution)
- **DynamoDB:** `GetItem`, `PutItem`, `DeleteItem`, `Query`, `Scan`

Pricing: First 2 million data events/month free. Additional: **$0.10 per 100,000 events**.

> **COST EXAMPLE**
>
> S3 bucket with 1M objects accessed daily = 30M GetObject events/month.
> Cost: (30M − 2M) ÷ 100,000 × $0.10 = **$28/month**

Recommendation: Enable for sensitive / compliance buckets only. Avoid enabling for all buckets (cost explosion). Use CloudFront logs for public content delivery.

CloudTrail Insights (ML-Based Anomaly Detection)

Learns normal API call patterns and detects significant deviations:

Insight Type	Indicates	Example
Unusual API Error Rates	Possible attack or misconfiguration	1,000 AccessDenied errors in 5 min (normal: 5/min)
Unusual API Call Volumes	Automation gone wrong, or active attack	500 RunInstances calls (normal: 10/day)

Pricing: $0.35 per 100,000 write management events analyzed (~$5–50/month).
Recommended for all production accounts.

SECTION 06

Multi-Account Strategies

Organization Trail — Centralized Audit Logging

An organization trail from the master account logs events from all member accounts into a single S3 bucket. Member accounts cannot disable or modify it.

ARCHITECTURE

```
AWS Organization ├── Master Account (123456789012) │ ├── Organization Trail: "org-trail" │ └── S3 Bucket: org-cloudtrail-logs ├── Production Account (234567890123) │ └── Events → Master S3 Bucket ├── Development Account (345678901234) │ └── Events → Master S3 Bucket └── Staging Account (456789012345) └── Events → Master S3 Bucket
```

S3 PATH STRUCTURE

```
s3://org-cloudtrail-logs/AWSLogs/ ├── o-abc123xyz/ (Organization ID) │ ├── 234567890123/ (Production) │ │ └── CloudTrail/us-east-1/2025/01/15/... │ ├── 345678901234/ (Development) │ └── 456789012345/ (Staging) └── 123456789012/ (Master)
```

Benefits of Organization Trails

- Centralized audit logs across all accounts
- Member accounts cannot disable the trail
- Simplified compliance reporting
- Cost optimization — single storage location (up to 90% cost reduction)
- Security isolation — member accounts have read-only view

Member Account Permissions

- Can view events in the CloudTrail console
- Cannot modify or delete the trail
- Cannot stop logging
- Logs automatically forwarded to the master account

SECTION 07

Cost Management & Optimization

Pricing Reference

Item	Price
Management events — first copy	**Free**
Management events — additional copies	$2.00 / 100,000 events
Data events (after 2M free/month)	$0.10 / 100,000 events
Insights events	$0.35 / 100,000 write events analyzed
S3 storage	$0.023 / GB-month
CloudWatch Logs ingestion	$0.50 / GB
CloudWatch Logs storage	$0.03 / GB-month

Typical Monthly Costs by Account Size

Account Size	CloudTrail Storage	CloudWatch	Total
Small (100 resources)	$2–5	$5–10	**$7–15/month**
Large (5,000 resources)	$150–300 (incl. selective data events)	$100–200	**$270–550/month**

Optimization Strategies

1. SELECTIVE DATA EVENTS

Approach	Scope	Estimated Cost
All S3 buckets (avoid)	100M GetObject events/month	$98/month
Sensitive buckets only (recommended)	5M GetObject events/month	$3/month

Savings: $95/month (97%)

2. S3 LIFECYCLE POLICY FOR LOG RETENTION

- Transition to S3-IA after 90 days
- Transition to Glacier after 1 year
- Delete after 7 years (or per compliance requirement)
- **Savings: ~80% on logs older than 90 days**

3. OPTIMIZE CLOUDWATCH LOGS

Set a **7-day retention** in CloudWatch for real-time alerting; rely on S3 for long-term storage. **Saves ~70% on CloudWatch costs.**

4. SELECTIVE CONFIG RECORDING

```
config.put_configuration_recorder({
    'ConfigurationRecorder': {
        'recordingGroup': {
            'allSupported': False,
            'resourceTypes': [
                'AWS::EC2::Instance',
                'AWS::S3::Bucket',
                'AWS::RDS::DBInstance',
                'AWS::IAM::User'
            ]  # Critical resources only
        }
    }
})
# Savings: 50-70% on Config costs
```

SECTION 08

Best Practices

1. **Enable Organization Trail Immediately**

   Centralized logging prevents individual accounts from disabling audit trails. Single S3 bucket reduces costs by up to 90%.

2. **Enable Log File Validation**

   SHA-256 cryptographic proof prevents tampering — essential for compliance and forensic investigations.

3. **Use Multi-Region Trails**

   A single multi-region trail covers all regions, simplifying management and ensuring complete coverage including global services like IAM and Route 53.

4. **Integrate with CloudWatch for Real-Time Alerts**

   Near real-time detection of suspicious activity — S3 delivery takes up to 15 minutes; CloudWatch provides alerts within seconds.

5. **Enable Insights for Production Accounts**

   ML-based anomaly detection catches unusual API patterns early. Well worth the $5–50/month cost for production environments.

6. **Deploy Conformance Packs**

   Pre-built rule collections for CIS, PCI DSS, and HIPAA compliance — deploy entire frameworks at once instead of individual rules.

7. **Implement Automated Remediation**

   Config rules that trigger SSM automation documents fix non-compliant resources automatically, reducing manual remediation time by ~95%.

SECTION 09

Pitfalls & Remedies

Pitfall 1: Missing Critical API Calls

Why it happens: Data events not enabled; regional trail missing events from other regions; CloudTrail disabled without detection; service-linked roles behave differently from regular IAM roles.

Impact: Security incidents go undetected, compliance violations, incomplete forensic investigations. Unable to answer "who accessed this data?"

Example scenario: Suspected data breach from an S3 bucket. CloudTrail has only management events enabled — no record of `GetObject` calls exists, making it impossible to determine if or by whom data was accessed. Result: incomplete investigation and potential regulatory penalties.

Remedy steps:

- Audit current CloudTrail configuration across all regions
- Enable data events for sensitive and compliance-scoped resources
- Set CloudWatch alarms for `StopLogging` events
- Use Service Control Policies (SCPs) to prevent trail deletion
- Enable organization trail so member accounts cannot disable logging

Pitfall 2: Excessive Storage Costs

Why it happens: No S3 lifecycle policies configured; data events enabled for all resources; Config recording all resource types; logs retained indefinitely with no archival strategy.

Growth scenario:

- Month 1 (all data events + all Config types): **$50**
- After 12 months — CloudTrail logs 500 GB: $11.50/month; Config data 2 TB: $900/month
- Total: **$911.50/month** (18× initial estimate) — Annual: $10,938

Prevention: Configure S3 lifecycle policies from day one; limit data events to sensitive resources; use selective Config recording; run monthly cost audits; set AWS Budgets alerts; archive to Glacier for long-term retention.

SECTION 10

Summary & Key Takeaways

AWS CloudTrail and AWS Config provide comprehensive governance, compliance, and audit capabilities through continuous API logging and resource configuration tracking. Together they answer the two critical governance questions: *"Who did what and when?"* (CloudTrail) and *"What resources exist and are they compliant?"* (Config).

CloudTrail events feed GuardDuty for threat detection, Config rules check resource compliance, Security Hub aggregates findings, and EventBridge triggers automated responses — making these services the audit foundation across the entire AWS ecosystem.

Key Takeaways

Organization Trail

Centralized logging for all accounts; member accounts cannot disable it; single S3 bucket reduces costs 90%.

Log File Validation

SHA-256 cryptographic proof prevents tampering; essential for compliance and forensic investigations.

CloudWatch Integration

Near real-time alerts; metric filters detect root account usage, unauthorized calls, security group changes.

Conformance Packs

Pre-built rule collections for CIS, PCI DSS, HIPAA; deploy entire compliance framework at once.

Config Aggregators

Single dashboard for multi-account compliance; cross-account queries identify systemic issues.

Automated Remediation

Config triggers SSM automation to fix non-compliant resources automatically; reduces manual work 95%.

Cost Optimization

S3 lifecycle to Glacier, selective data events, selective Config recording — combined savings ~70%.

CloudTrail Insights

ML-based early warning of credential compromise, misconfigured automation, and reconnaissance.

SECTION 11

Hands-On Lab Exercise

OBJECTIVE

Build a complete governance and compliance monitoring system with centralized logging, automated compliance checks, and incident investigation capabilities.

Scenario: Enterprise with multiple AWS accounts requiring CIS compliance, security audit trails, and automated remediation.

Prerequisites: AWS Organization with 2+ accounts; Admin access to master and member accounts.

Estimated total time: ~3 hours

1. **Enable Organization Trail** (40 min)
   - 2. Create S3 bucket with encryption and versioning
   - 3. Configure bucket policy for CloudTrail
   - 4. Create organization trail (multi-region)
   - 5. Enable log file validation
   - 6. Integrate with CloudWatch Logs
   - 7. Enable CloudTrail Insights
   - 8. Verify logging from all member accounts

9. **Configure CloudWatch Alarms** (30 min)
   - 10. Create metric filters (root usage, unauthorized calls, security group changes)
   - 11. Create CloudWatch alarms for each metric
   - 12. Configure SNS notifications
   - 13. Test alarms with manual state change
   - 14. Verify email alerts received

15 **Enable AWS Config** (45 min)

- 16 Create Config S3 bucket
- 17 Enable Config recorder in all regions
- 18 Deploy CIS conformance pack
- 19 Create Config aggregator (master account)
- 20 Verify member account data is aggregated
- 21 Review compliance dashboard

---

22 **Configure Automated Remediation** (30 min)

- 23 Enable `s3-bucket-public-read-prohibited` Config rule
- 24 Configure automatic remediation (block public access)
- 25 Test with an intentionally public bucket
- 26 Verify automatic remediation within 5 minutes
- 27 Confirm bucket is now compliant

---

28 **Investigate a Security Incident** (30 min)

- 29 Generate sample security event (create IAM user)
- 30 Query CloudTrail for the event

- 31 Use CloudWatch Logs Insights to analyze
- 32 Reconstruct timeline of events
- 33 Export findings to a report

Expected Outcomes

- Complete audit trail for all API calls across the organization
- CIS compliance score visible in the Config dashboard
- Automated remediation of non-compliant resources
- CloudWatch alarms detecting suspicious activity
- Ability to investigate security incidents rapidly
- Estimated total cost: **$50–100/month** for a 5-account organization